



3. 세션 재검증 인터셉터

담당: 이정하

개요

보호 경로 접근 시마다 세션 스냅샷이 아닌 DB의 최신 계정 상태로 재검증하는 인터셉터. 정지·탈퇴된 계정은 다음 요청에서 즉시 차단된다.

- 구현 파일: `security/LoginRequiredInterceptor.java`, `config/WebMvcConfig.java`

핵심 포인트

- 로그인 시점의 세션 정보를 믿지 않는다. 보호 경로(`/learning/**`, `/settings/**` 등)는 세션 유무만 보지 않고 매 요청 DB에서 계정 상태를 다시 조회한다.
- 정지·탈퇴로 바뀐 계정은 세션을 무효화하고 로그인 화면으로 보낸다.
- 재검증에 성공하면 최신 사용자 정보(닉네임·프리미엄 여부 등)로 세션을 갱신해 화면과 DB가 어긋나지 않는다.
- 비로그인 접근 시 원래 가려던 경로를 `redirect` 파라미터로 보존해 로그인 후 그 자리로 돌려보낸다.

주요 코드

위치: `security/LoginRequiredInterceptor.java` 24~49행 (`preHandle`, 개발용 플래그 분기 생략)

```
@Override
public boolean preHandle(HttpServletRequest request, HttpServletResponse response, Object handler) {
    SessionUser sessionUser = currentUser(request);
    if (sessionUser == null) {
        response.sendRedirect("/login?redirect=" + encodedCurrentPath(request));
        return false;
    }
}
```

```

    }

    // 정지된 계정이면 세션 무효화 후 로그인으로
    Optional<SessionUser> refreshed = authService.revalidate(
        sessionUser.userId());
    if (refreshed.isEmpty()) {
        HttpSession session = request.getSession(false);
        if (session != null) {
            session.invalidate();
        }
        response.sendRedirect("/login?redirect=" + encodedC
            urrentPath(request));
        return false;
    }
    request.getSession(false).setAttribute(SessionUser.SESS
        ION_KEY, refreshed.get());
    return true;
}

```

시연 화면

1. 로그아웃 상태로 `/learning` 접근 → `/login?redirect=%2Flearning` 으로 리다이렉트되어 로그인 화면 표시 (로그인 성공 시 원래 경로로 복귀)

